v0.59 — Tenant CRUD Security Validation

Checkpoint: 11 November 2026 | Status: Offline-tested development only

RELEASE DECISION: NO-GO

The v0.59 source improves the quality of real PostgreSQL tenant-isolation testing. The application has **not** been approved for production, customer data, commercial payments or title certification.

What was corrected

The earlier seeded two-organization test checked that one tenant could not modify another tenant's rows. That can overlook a broken, read-only implementation. The v0.59 contract now requires authorized operations to succeed *and* unauthorized operations to fail.

• A restricted, non-superuser PostgreSQL login must insert, update, read and delete **its own** records across assets, verification cases, evidence and documents.

• The same login must not read or change another organization's data; cross-tenant inserts must be rejected.

• Transaction-local tenant context must be removed after both **ROLLBACK** and **COMMIT**, and temporary writes must leave no retained records.

• The supervised test order is fixed: **restricted role (v57)** → **seeded isolation (v58)** → **authorized/denied CRUD (v59)**.

• Dangerous database targets are rejected before connections. Live tests require separate operator/runtime roles, a disposable local database and explicit mutation authorization.

Verified offline evidence

Control	Result
New v0.59 test cases	15 / 15 PASS
Complete version suites v0.03–v0.59	57 / 57 PASS
Migration SQL hashes vs v0.58	25 / 25 unchanged
CI YAML, architecture, source syntax	PASS
Current-source secret pattern scan	0 high-confidence matches / 2,611 files

Release blockers and next validation

Evidence we do NOT have

• **Real npm install:** authentic package-lock.json absent; npm registry DNS unavailable here. Do not manufacture or bypass the lockfile.

• **Full API/web build:** FAILED on missing installed Node, NestJS and PostgreSQL typings/dependencies. The 104-file source syntax check is not a build.

• **Real PostgreSQL:** no local service/runtime role available. The v0.59 live contract is prepared but NOT EXECUTED.

• **Other gates:** real ClamAV, authenticated browser flows, two-API HTTP validation, original Git-history audit, HTTPS infrastructure, backup restoration, penetration and legal review are outstanding.

• **Release preflight:** 3 of 11 prerequisites present. This is not a readiness percentage for all product features.

Controls and limitations

Seven specific tables have row-level security implemented in the source; many other private tables remain outside that protection. PostgreSQL tenant settings are defense-in-depth and cannot replace application authorization, safe SQL, scoped privileges and independent security testing.

The new synthetic fixture test is limited to **localhost** and the disposable databases **assettrust_ci** or **assettrust_test**. Production or shared databases are prohibited. A stopped process may leave synthetic fixtures: discard the disposable database rather than guessing what changed.

Kali execution sequence

1. Inspect and generate a real dependency lockfile on a trusted registry connection; run **npm ci**, dependency audit, both builds, and browser artifact gate.

2. Create a fresh disposable PostGIS database and run all 25 migrations. Provision the restricted CI runtime login using the existing private-file workflow.

3. Run **test:pg:runtime-role:v57**, **test:pg:runtime-tenant-isolation:v58**, then **test:pg:runtime-tenant-crud:v59**. Keep redacted logs and verify the new contract’s positive assertion count.

4. Run the remaining integration, operational, security and legal checks before reconsidering deployment. See **V59_KALI_VALIDATION.md** and **TEST_EVIDENCE_V59.md** in the ZIP.

Final assessment

Offline implementation milestone: complete. **Production release:** NO-GO. AssetTrust must not represent its reports as government-certified ownership or title verification without proper official authority and legal integration.